ZAP Scanning Report

Site: http://host.docker.internal:8091

Generated on Sat, 7 Nov 2026 14:26:17

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	1
Medium	2
Low	9
Informational	3
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	http://host.docker.internal:8091	Percentage of responses with status code 2xx	81 %
Info	Informational	http://host.docker.internal:8091	Percentage of responses with status code 3xx	9 %
Info	Informational	http://host.docker.internal:8091	Percentage of responses with status code 4xx	9 %
Info	Informational	http://host.docker.internal:8091	Percentage of endpoints with content type application/javascript	11 %
Info	Informational	http://host.docker.internal:8091	Percentage of endpoints with content type image/png	22 %
Info	Informational	http://host.docker.internal:8091	Percentage of endpoints with content type text/css	11 %
Info	Informational	http://host.docker.internal:8091	Percentage of endpoints with content type text/html	44 %
Info	Informational	http://host.docker.internal:8091	Percentage of endpoints with content type text/plain	11 %
Info	Informational	http://host.docker.internal:8091	Percentage of endpoints with method GET	88 %
Info	Informational	http://host.docker.internal:8091	Percentage of endpoints with method POST	11 %

Info	Informational	http://host.docker.internal:8091	Count of total endpoints	9
Info	Informational	http://host.docker.internal:8091	Percentage of slow responses	72 %

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
PHP Version with Known Vulnerabilities	High	1
Content Security Policy (CSP) Header Not Set	Medium	4
Missing Anti-clickjacking Header	Medium	3
Big Redirect Detected (Potential Sensitive Information Leak)	Low	1
Cookie No HttpOnly Flag	Low	4
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	3
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	3
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	Systemic
Permissions Policy Header Not Set	Low	5
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	5
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
Non-Storable Content	Informational	5
Session Management Response Identified	Informational	6
Storable and Cacheable Content	Informational	5

Alert Detail

High	PHP Version with Known Vulnerabilities
Description	The server disclosed the version of a server side technology it is running via an HTTP response header, and that version is affected by known vulnerabilities. The version, header and vulnerabilities, listed by severity, are given in the other info. See the references for the details of each. Note that some distributions backport security fixes without changing the version number, so check whether the fixes have actually been applied before reporting these as confirmed.
URL	http://host.docker.internal:8091/sitemap.xml
Node Name	http://host.docker.internal:8091/sitemap.xml
Method	GET

Parameter	
Attack	
Evidence	PHP/8.3.36
Other Info	The server disclosed that it is running PHP version 8.3.36 via the "X-Powered-By" HTTP response header. 3 known vulnerabilities: 0 critical, 2 high, 1 medium, 0 low. The version disclosed is older than any version listed in the advisories, so it is assumed to be affected because older, end-of-life release branches rarely receive fixes. High: CVE-2026-17544, CVE-2026-7263 Medium: CVE-2026-6104
Instances	1
Solution	Upgrade PHP to a supported version which includes fixes for the listed vulnerabilities. Also configure the server not to disclose the PHP version, e.g. by setting "expose_php = Off" in php.ini and suppressing version details in the "Server" header.
Reference	https://www.php.net/supported-versions.php https://github.com/php/php-src/security/advisories https://www.zaproxy.org/docs/desktop/addons/passive-scan-rules/php-known-vulnerabilities/#cve-2026-17544 https://www.zaproxy.org/docs/desktop/addons/passive-scan-rules/php-known-vulnerabilities/#cve-2026-7263 https://www.zaproxy.org/docs/desktop/addons/passive-scan-rules/php-known-vulnerabilities/#cve-2026-6104
CWE Id	1395
WASC Id	13
Plugin Id	20020

Medium	**Content Security Policy (CSP) Header Not Set**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET

Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/sitemap.xml
Node Name	http://host.docker.internal:8091/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	**Missing Anti-clickjacking Header**
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	x-frame-options
Attack	
Evidence	

Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	3
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	**Big Redirect Detected (Potential Sensitive Information Leak)**
Description	The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensitive details, PII, etc.).
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login ()(_token,password,usuario)
Method	POST
Parameter	
Attack	
Evidence	
Other Info	Location header URI length: 38 [http://host.docker.internal:8091/login]. Predicted response size: 338. Response Body Length: 398.

Instances	1
Solution	Ensure that no sensitive information is leaked via redirect responses. Redirect responses should have almost no content.
Reference	
CWE Id	201
WASC Id	13
Plugin Id	10044

Low	**Cookie No HttpOnly Flag**
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login ()(_token,password,usuario)
Method	POST
Parameter	XSRF-TOKEN
Attack	

Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
Instances	4
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	**Cross-Origin-Embedder-Policy Header Missing or Invalid**
Description	Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-

	origin-embedder-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	**Cross-Origin-Opener-Policy Header Missing or Invalid**
Description	Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	**Cross-Origin-Resource-Policy Header Missing or Invalid**
Description	Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/images/favicon-translogistica.png
Node Name	http://host.docker.internal:8091/images/favicon-translogistica.png
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/images/logo-translogistica.png
Node Name	http://host.docker.internal:8091/images/logo-translogistica.png
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/robots.txt

Node Name	http://host.docker.internal:8091/robots.txt
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	**Permissions Policy Header Not Set**
Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	
Attack	
Evidence	

Other Info	
URL	http://host.docker.internal:8091/build/assets/app-ETuu0FI7.js
Node Name	http://host.docker.internal:8091/build/assets/app-ETuu0FI7.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:8091/sitemap.xml
Node Name	http://host.docker.internal:8091/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	5
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

Low	**Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)**
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://host.docker.internal:8091

Node Name	http://host.docker.internal:8091
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: PHP/8.3.36
Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: PHP/8.3.36
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: PHP/8.3.36
Other Info	
URL	http://host.docker.internal:8091/sitemap.xml
Node Name	http://host.docker.internal:8091/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: PHP/8.3.36
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login ()(_token,password,usuario)
Method	POST
Parameter	
Attack	
Evidence	X-Powered-By: PHP/8.3.36
Other Info	
Instances	5

Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	**Server Leaks Version Information via "Server" HTTP Response Header Field**
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	
Attack	
Evidence	nginx/1.30.6
Other Info	
URL	http://host.docker.internal:8091/images/favicon-translogistica.png
Node Name	http://host.docker.internal:8091/images/favicon-translogistica.png
Method	GET
Parameter	
Attack	
Evidence	nginx/1.30.6
Other Info	
URL	http://host.docker.internal:8091/images/logo-translogistica.png
Node Name	http://host.docker.internal:8091/images/logo-translogistica.png
Method	GET
Parameter	
Attack	
Evidence	nginx/1.30.6
Other Info	
URL	http://host.docker.internal:8091/robots.txt
Node Name	http://host.docker.internal:8091/robots.txt
Method	GET
Parameter	
Attack	

Evidence	nginx/1.30.6
Other Info	
URL	http://host.docker.internal:8091/sitemap.xml
Node Name	http://host.docker.internal:8091/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	nginx/1.30.6
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	**X-Content-Type-Options Header Missing**
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8091/images/favicon-translogistica.png
Node Name	http://host.docker.internal:8091/images/favicon-translogistica.png
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	

Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8091/images/logo-translogistica.png
Node Name	http://host.docker.internal:8091/images/logo-translogistica.png
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:8091/robots.txt
Node Name	http://host.docker.internal:8091/robots.txt
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)

	https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Non-Storable Content
Description	The response contents are not storable by caching components such as proxy servers. If the response does not contain sensitive, personal or user-specific information, it may benefit from being stored and cached, to improve performance.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	
Attack	
Evidence	private
Other Info	
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	
Attack	
Evidence	private
Other Info	
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	
Attack	
Evidence	private
Other Info	
URL	http://host.docker.internal:8091/sitemap.xml
Node Name	http://host.docker.internal:8091/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	private
Other Info	
URL	http://host.docker.internal:8091/login

Node Name	http://host.docker.internal:8091/login ()(_token,password,usuario)
Method	POST
Parameter	
Attack	
Evidence	private
Other Info	
Instances	5
Solution	The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Informational	**Session Management Response Identified**
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET

Parameter	laravel-session
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	laravel-session
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login
Method	GET
Parameter	laravel-session
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://host.docker.internal:8091/login
Node Name	http://host.docker.internal:8091/login ()(_token,password,usuario)
Method	POST
Parameter	laravel-session
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://host.docker.internal:8091
Node Name	http://host.docker.internal:8091
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	XSRF-TOKEN
Other Info	cookie:XSRF-TOKEN

URL	http://host.docker.internal:8091/
Node Name	http://host.docker.internal:8091/
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	XSRF-TOKEN
Other Info	cookie:XSRF-TOKEN
Instances	6
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	**Storable and Cacheable Content**
Description	The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	http://host.docker.internal:8091/build/assets/app-ETuu0FI7.js
Node Name	http://host.docker.internal:8091/build/assets/app-ETuu0FI7.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:8091/build/assets/bootstrap-BPQQccdV.css
Node Name	http://host.docker.internal:8091/build/assets/bootstrap-BPQQccdV.css
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:8091/images/favicon-translogistica.png
Node Name	http://host.docker.internal:8091/images/favicon-translogistica.png

Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:8091/images/logo-translogistica.png
Node Name	http://host.docker.internal:8091/images/logo-translogistica.png
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:8091/robots.txt
Node Name	http://host.docker.internal:8091/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
Instances	5
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Sequence Details

With the associated active scan results.